

Remote Access Trojan (RAT) Spyware Task

By: Hadeer Amr Fawzy

Introduction to the task

This laboratory exercise simulates the complete lifecycle of a Remote Access Trojan (RAT) attack on a controlled Windows test environment. The objective was to understand and perform each stage of an targeted cyber spying operation, ranging from initial payload development through command-and-control setup and ultimate data exfiltration. This simulation-based exercise provides useful insights into modern malware tactics, techniques, and procedures (TTPs) adopted by adversaries in real-world attacks.

The test was conducted using two virtual machines: the attacker/command and control (Builder/Handler) and the target (Victim). The attack utilized njRAT and ProRat, a typical Windows remote administration tools often weaponized as a malicious tool, to demonstrate how unauthorized remote access can be created and maintained for espionage purposes.

Executive summary

Lab Objective:

Successfully demonstrate the end-to-end attack cycle of a RAT-based espionage operation, from payload development to data exfiltration.

Methodology:

The attack was simulated in three distinct phases:

Attacker Setup: Configured njRAT and ProRat builder with persistence mechanisms and established C2 listener

Victim Compromise: Delivered malicious payload through network share and achieved initial access

Espionage Operations: Conducted remote monitoring like system discovery, screenshot capture, and keystroke logging

Key Findings:

Successfully developed a long-term RAT payload like "server.exe" and "openMe.exe"

Successfully established a reliable C2 channel on TCP port 5552 and 5110

Employed two persistence mechanisms (Startup Folder + Registry Run keys)

Successfully captured sensitive victim data like desktop captures and keystroke logon with spoofed credentials

Enjoyed sustained remote-control access that could resist system reboot

Impact:

The exercise demonstrates how easily an attacker can gain full control of a compromised system, highlighting the absolute need for defense-in-depth policies, user awareness, and proper endpoint security to detect and prevent such intrusions within enterprise networks.

The lab successfully met all goals, with concrete evidence of RAT capabilities and underscoring the importance of comprehensive security measures against remote access attacks.

NTI Ethical Hacking

Lab topology

VM Role	IP Address	OS and Role
Builder/Handler	192.168.1.26 due to restart 192.168.68.175	Windows 7 (RAT Builder & C2 Handler)
Victim	192.168.1.27 due to restart 192.168.68.158	Windows 7 Client

Steps with screenshots

First I got the Ips then they changed due to restarting Our mission began on the "Builder/Handler" machine (our attacker computer, at IP address 192.168.1.100). Think of this as our mission control.

```
Command Prompt
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\attacker>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::54e0:bdc:46e:724f%11
    IPv4 Address. . . . . : 192.168.1.26
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1

Tunnel adapter isatap.{4B3553BD-A89F-45C7-9956-857184D7E3A3}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :
```

Attacker

```
Administrator: Command Prompt

C:\Users\IEUser>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection 2:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::b899:9db7:7374:ecc0%13
    IPv4 Address. . . . . : 192.168.1.27
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1

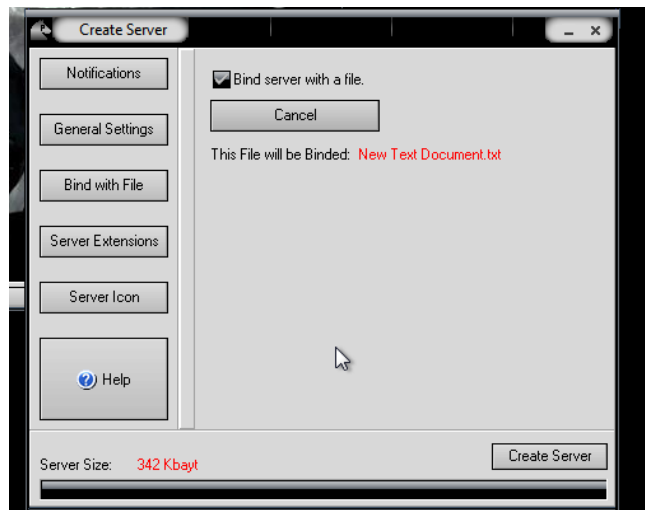
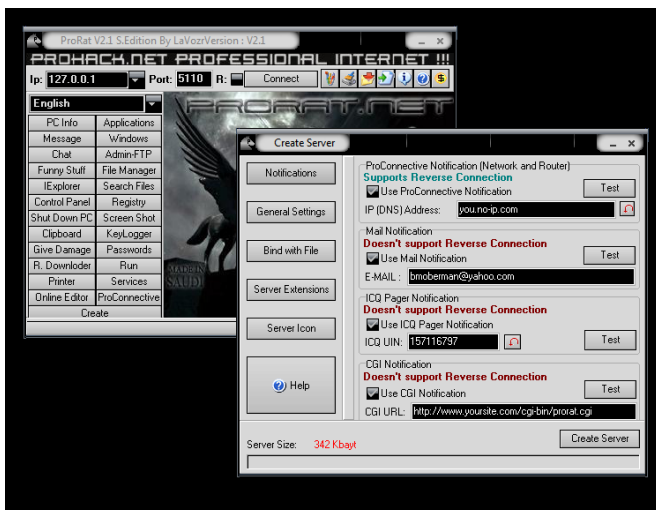
Tunnel adapter isatap.{C383C514-4C3F-41E4-A728-F11F1B5628AA}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :
```

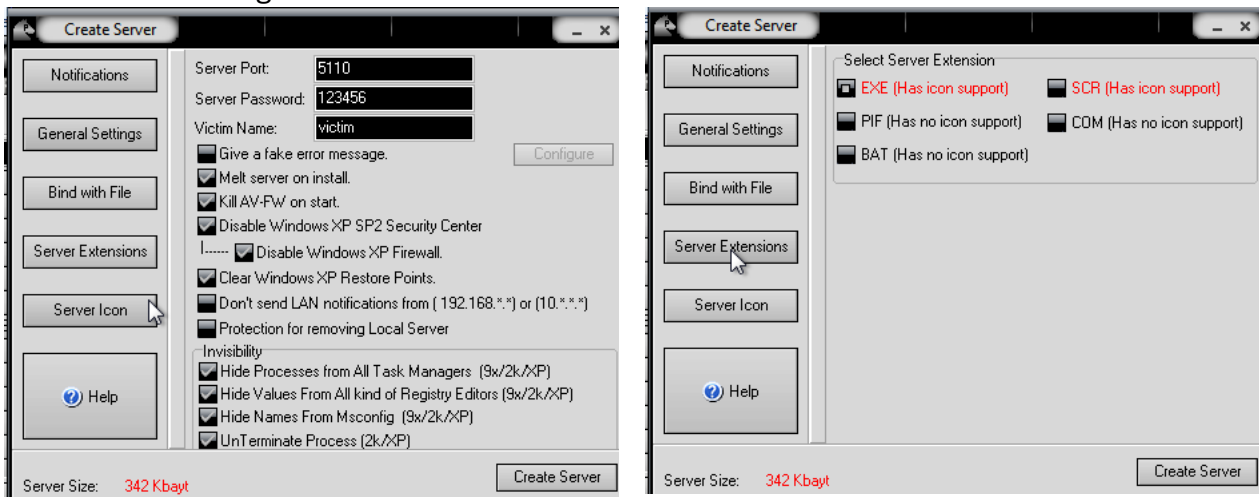
Victim

Attacker Setup and Payload Generation (Builder/Handler VM)

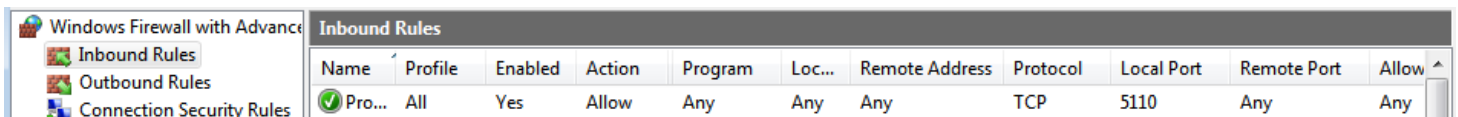
this was my first trail using ProRat I set it up In the main ProRat window, I clicked the "Create" button and selected "Create ProRat Server" I set this to our handler's IP: 192.168.1.27 and I used port 5110 "default" to avoid confusion with other services and kept it as .exe and zipped it.



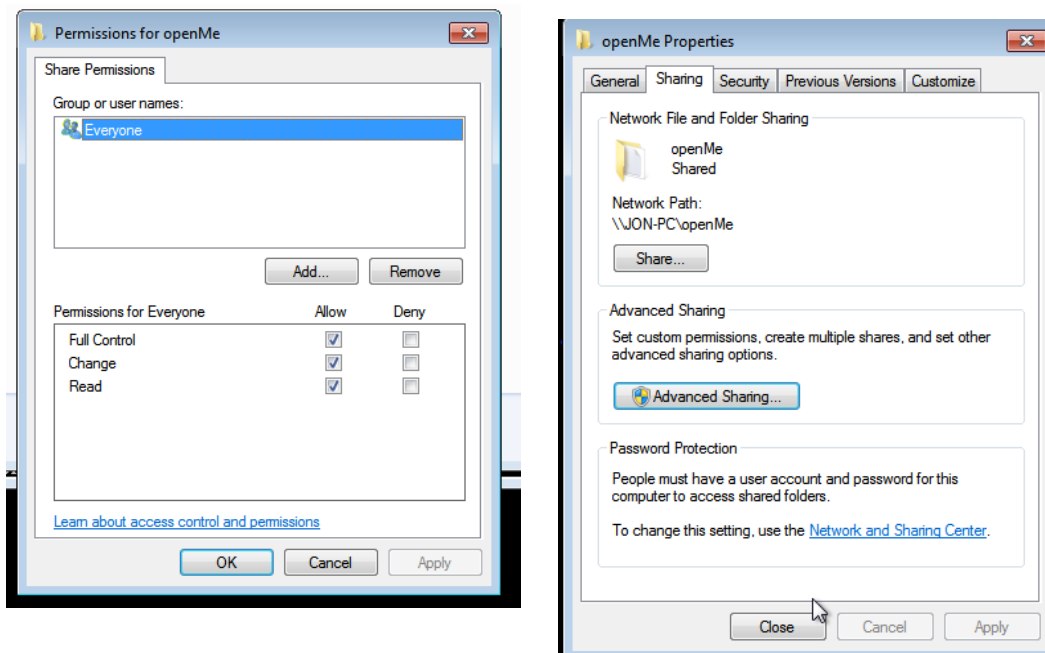
NTI Ethical Hacking



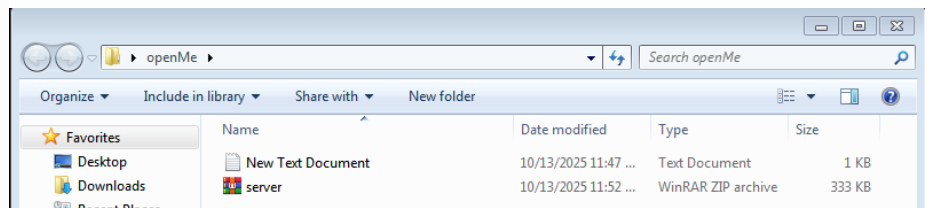
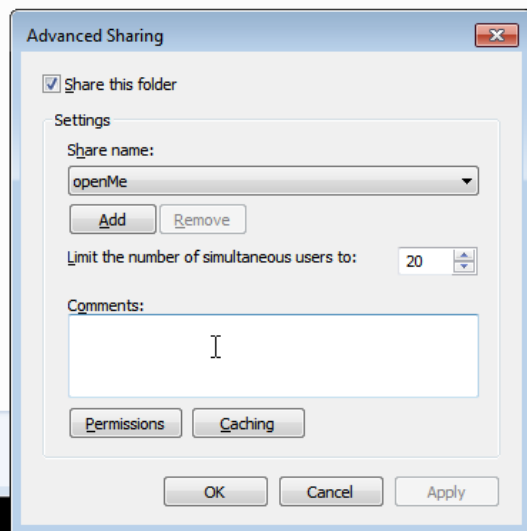
And I created firewall inbound rule to fit this port



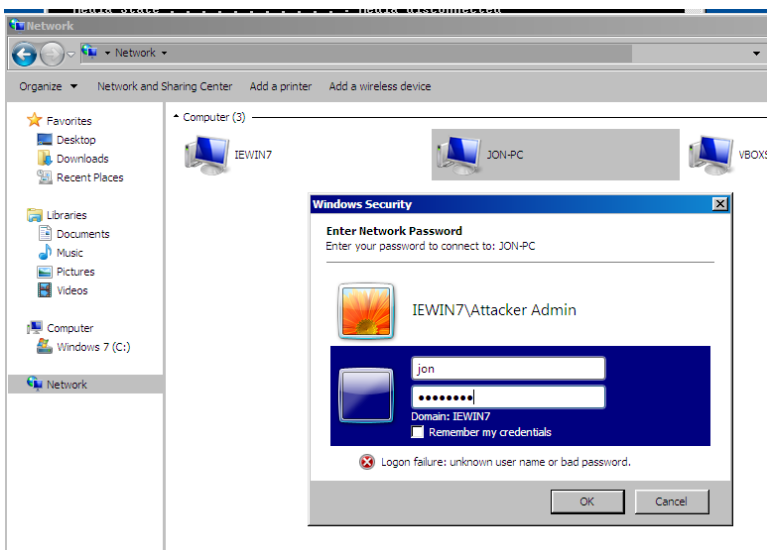
Then I go and add permissions to the file I shared with the victim and put the server in it



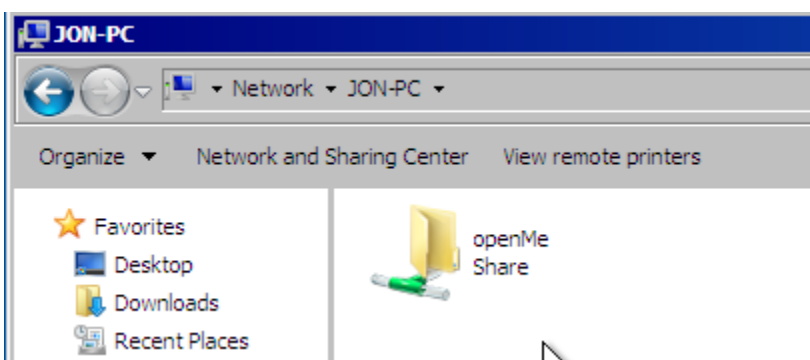
NTI Ethical Hacking



Establish the Delivery Vector via Shared Folder

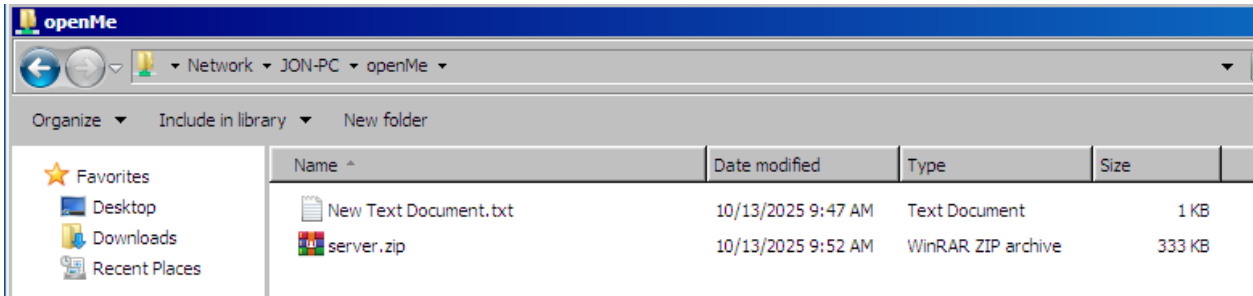


And successfully I opened the file from the victim machine and run it also after some research



NTI Ethical Hacking

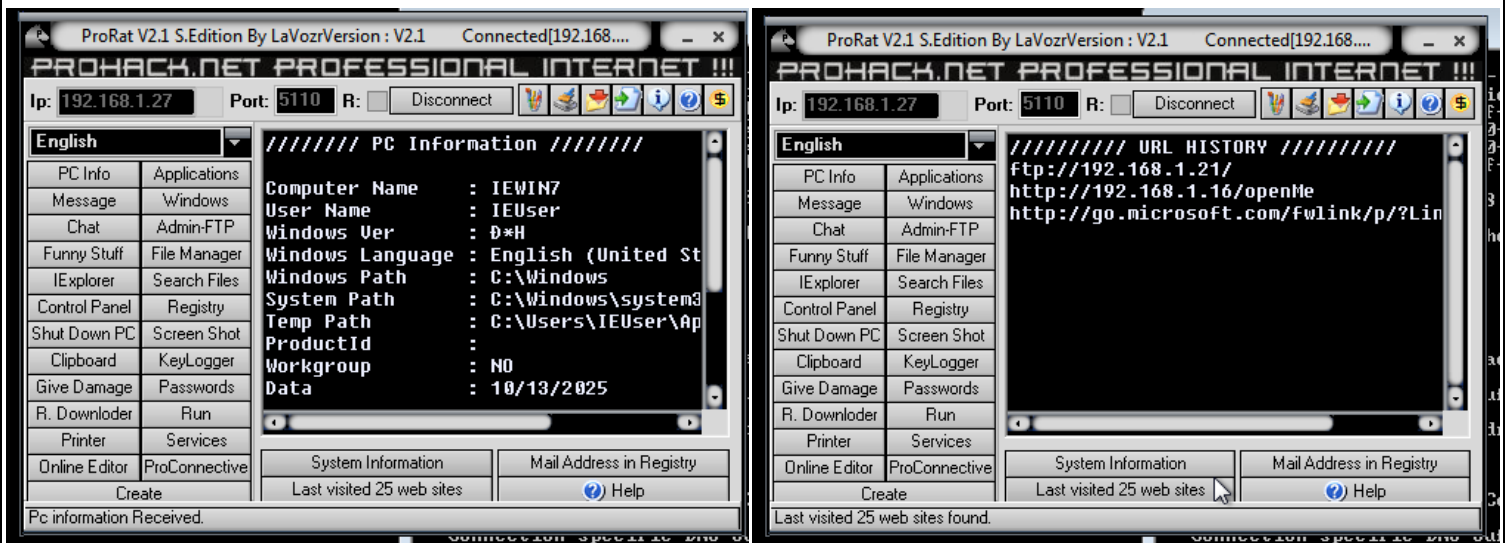
Victim Preparation and Payload Execution



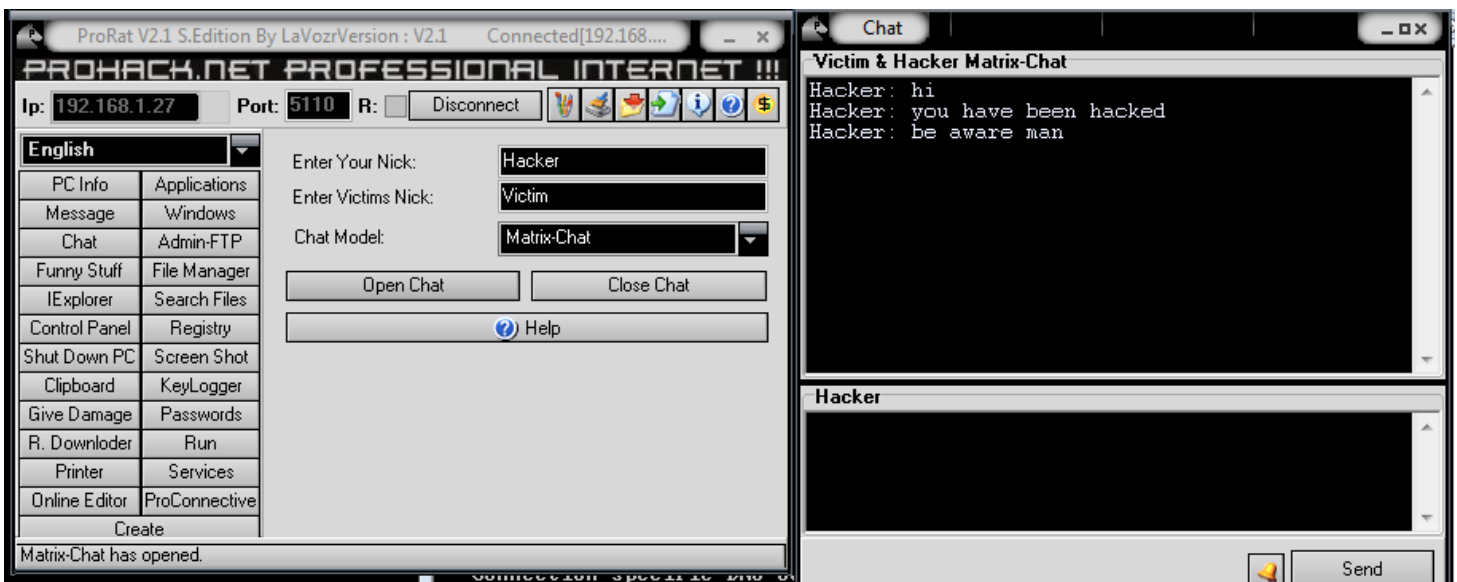
Espionage and Data Collection

I saw the magic happen in the ProRat main window. A new entry appeared in the connection list, showing the Victim's IP address

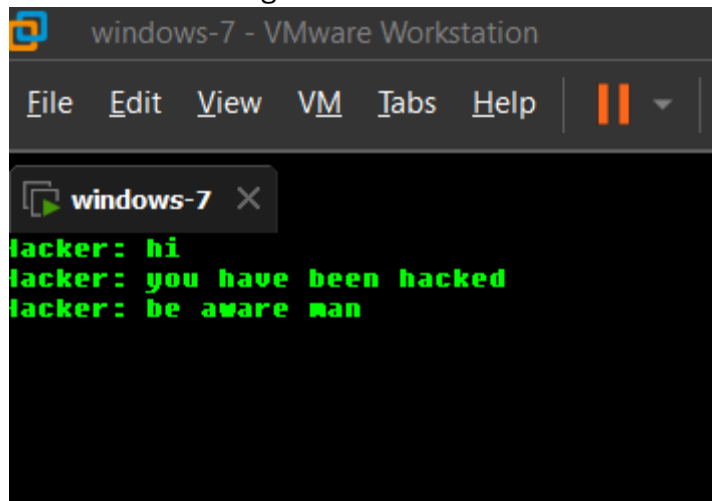
And simply I got PC info and last visited websites



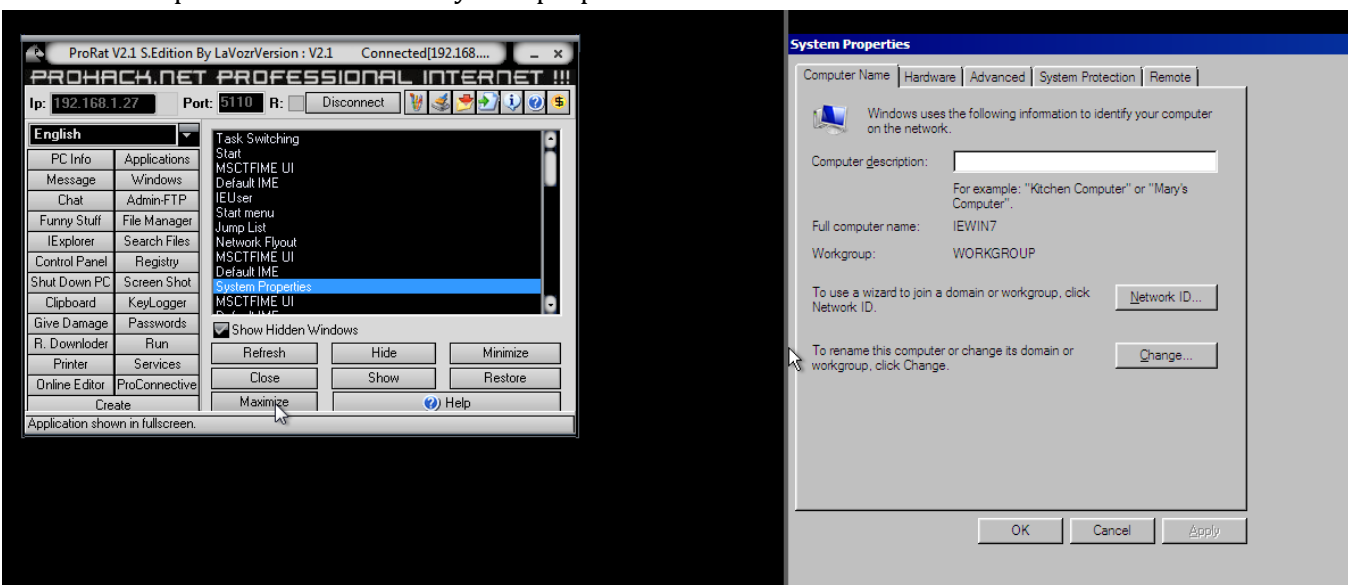
Then I went to chat option and I chatted with the victim and he can not exit this chat



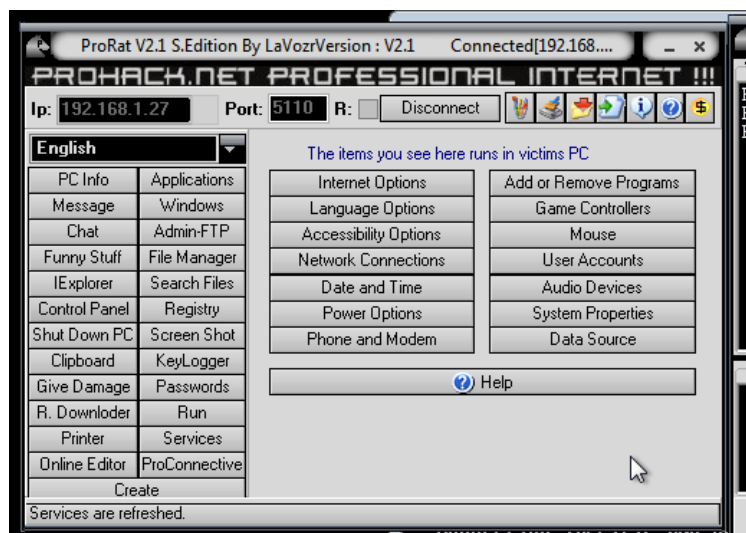
NTI Ethical Hacking



And I could open some services as system properties

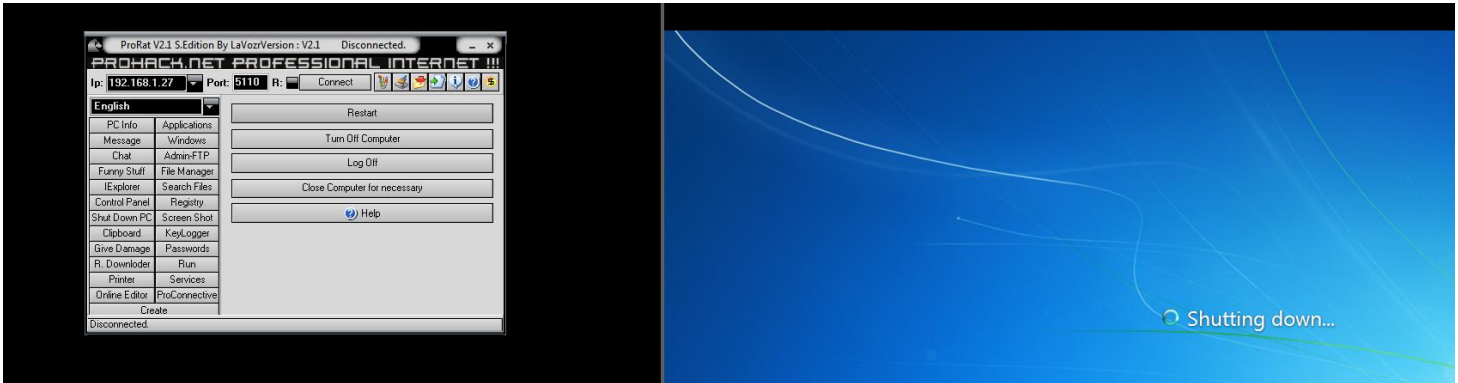


and I could mess with another things remotely

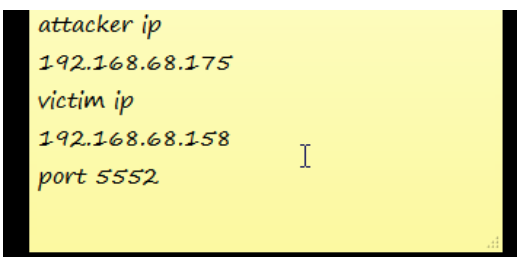
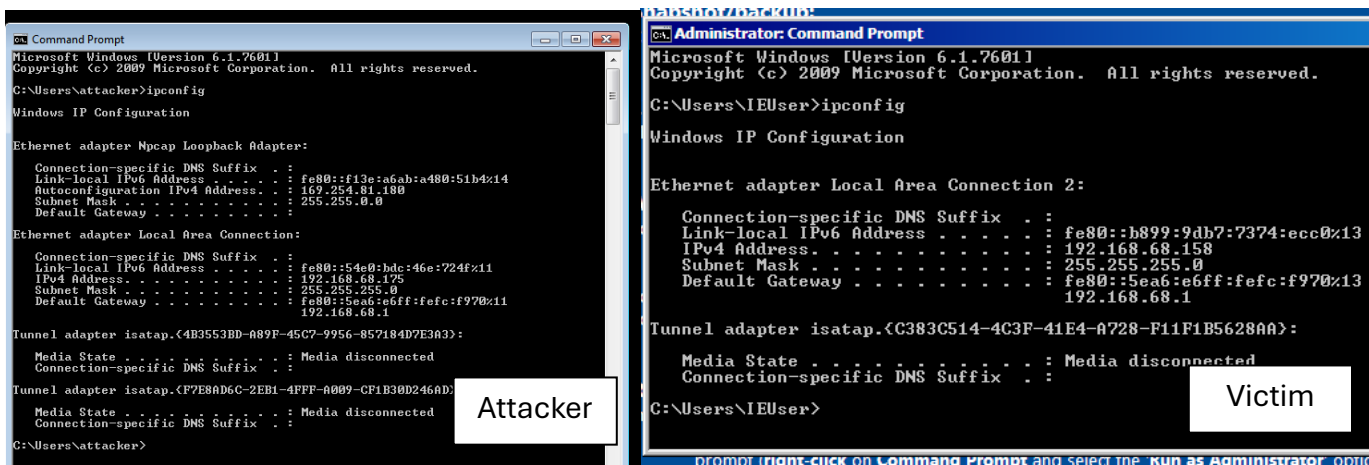


NTI Ethical Hacking

And finally from the attacker machine I could shut down the victim machine



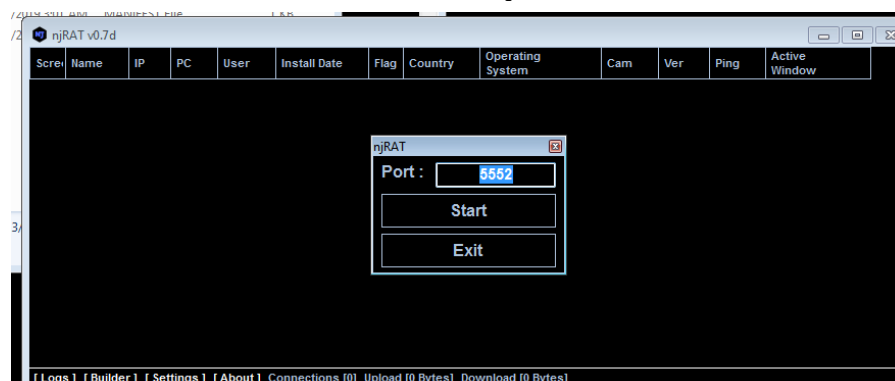
New ips after restarting all machines



Attacker Setup and Payload Generation

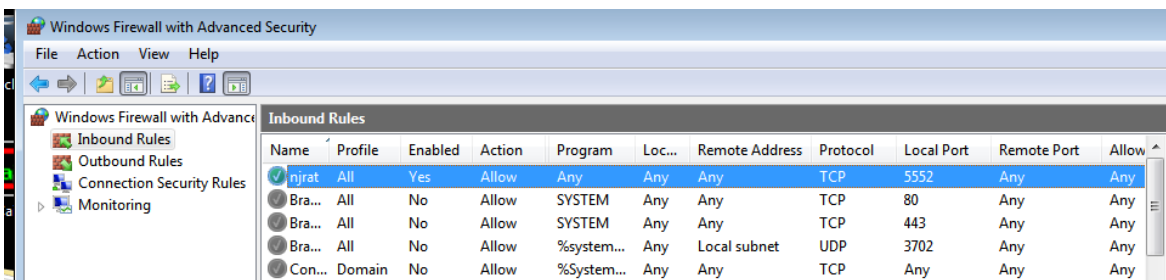
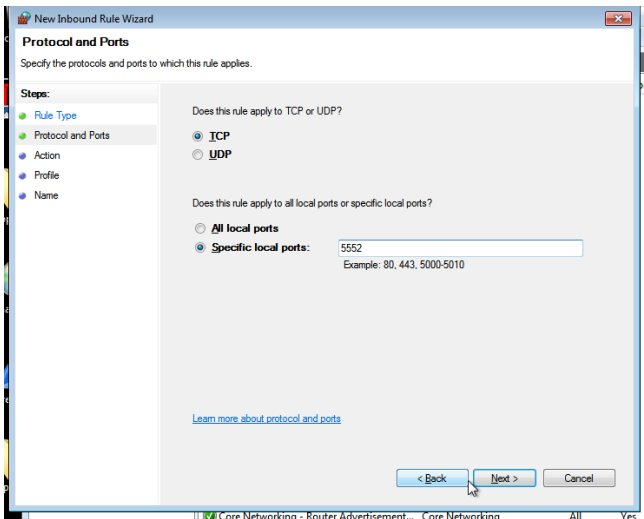
Next, we opened the njRAT builder tool. This is the software that lets us create the custom malicious file. We configured it like a meticulous spy crafting a false identity:

Listener Port: We instructed it to use our secret backdoor, port 5552 “default”.



NTI Ethical Hacking

I had to prepare a way for the victim to call back to us. I carved out a special rule on attacker machine firewall. This rule essentially said, "Any incoming connections on TCP Port 5552 are allowed and welcome. And to ensure my lab worked without interference, I temporarily disabled the victim's built-in security. This included turning off Windows Firewall and any real-time antivirus protection. In a real attack, the malware would have to do this itself or evade detection.

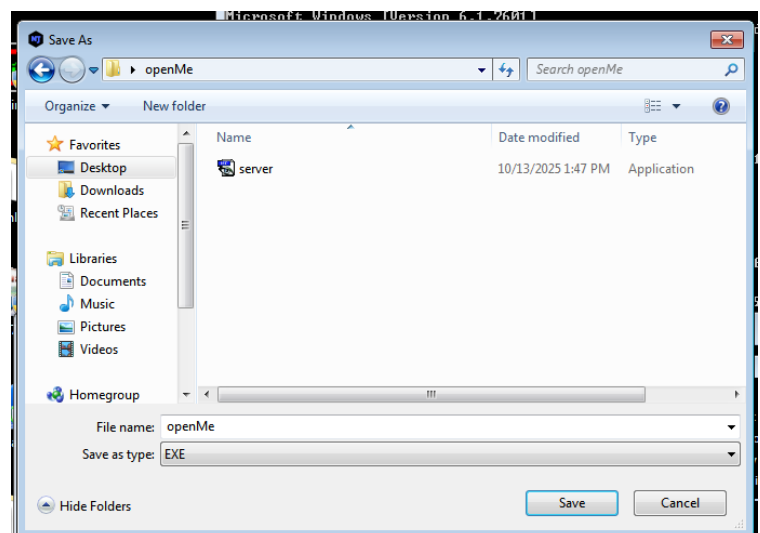
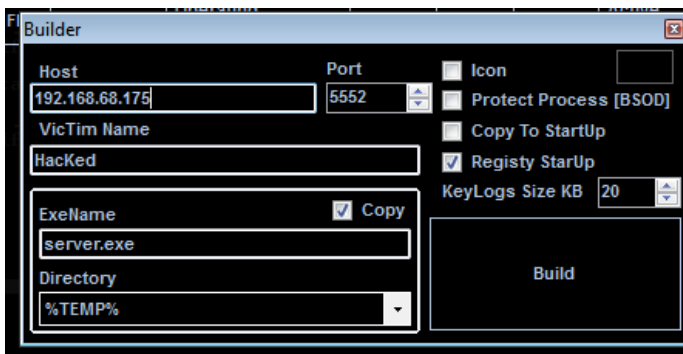


C2 Address: We told it to call home to our machine (192.168.68.175).

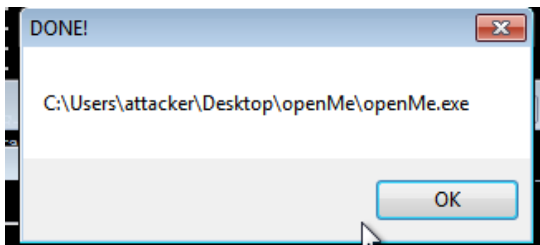
Persistence - The "Comeback" Mechanism: This was a critical step. We enabled the Startup Folder and Registry Run options. This ensures that even if the victim restarts their computer, our spyware automatically reactivates on login, like a sleeper agent that never truly leaves.

Disguise: We gave the output file a harmless-sounding name: openMe.exe. It's designed to blend in and look like a legitimate Windows process.

With everything configured, we clicked "Build." The tool generated our finished, weaponized openMe.exe file, ready for delivery.

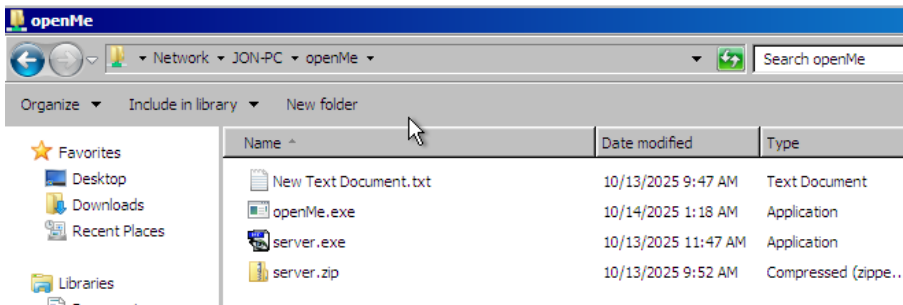


NTI Ethical Hacking



Establish the Delivery Vector via Shared Folder

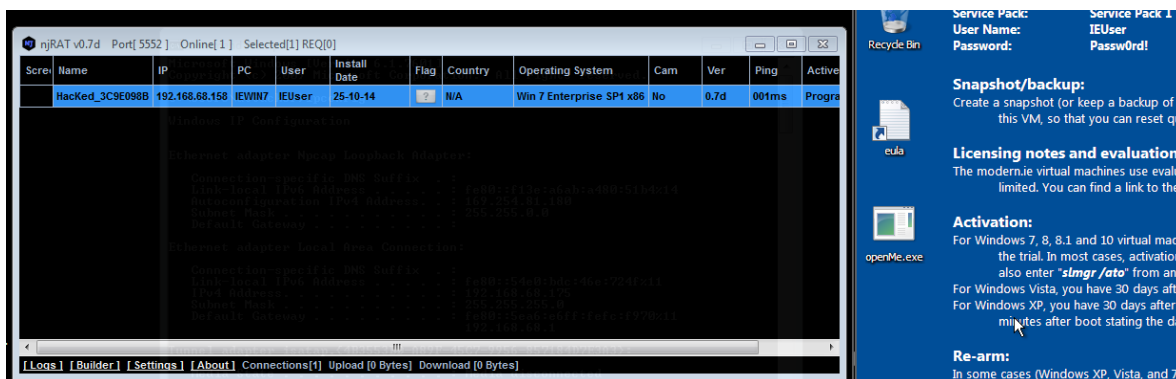
As the "user," I browsed to the attacker's shared folder (\\JoN-PC\openMe), saw the openMe.exe file, and believed it to be a legitimate file copied it to our Desktop and double-clicked it.



Victim Preparation and Payload Execution

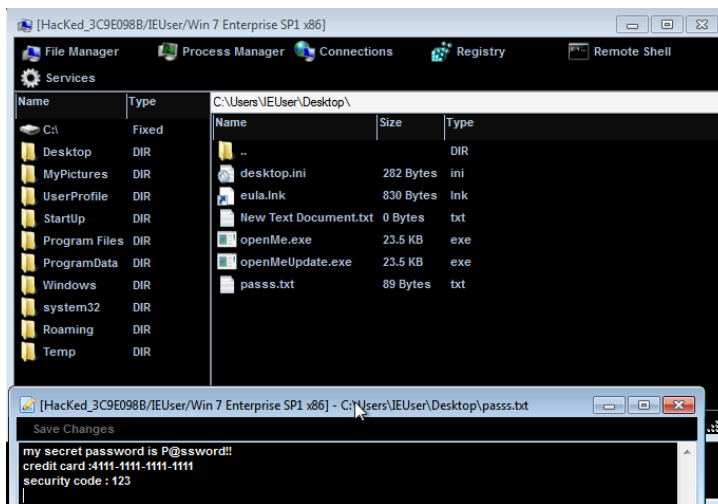


The moment the file was executed, we immediately switched back to our Builder/Handler machine. A beautiful sight awaited us in the njRAT control panel: a new, active connection from the victim's IP address (192.168.68.158). Our trap had sprung, and we now had a live, remote-control link to the victim's computer.

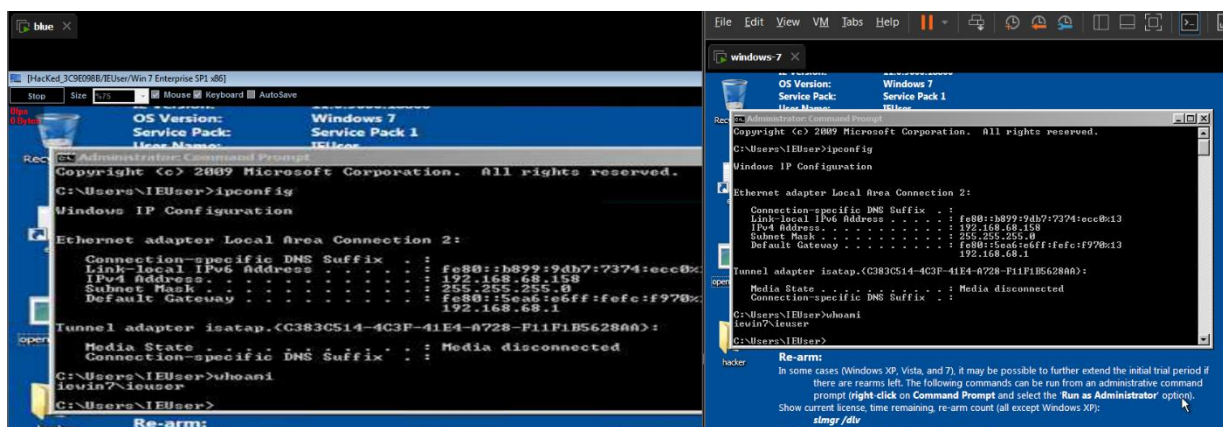
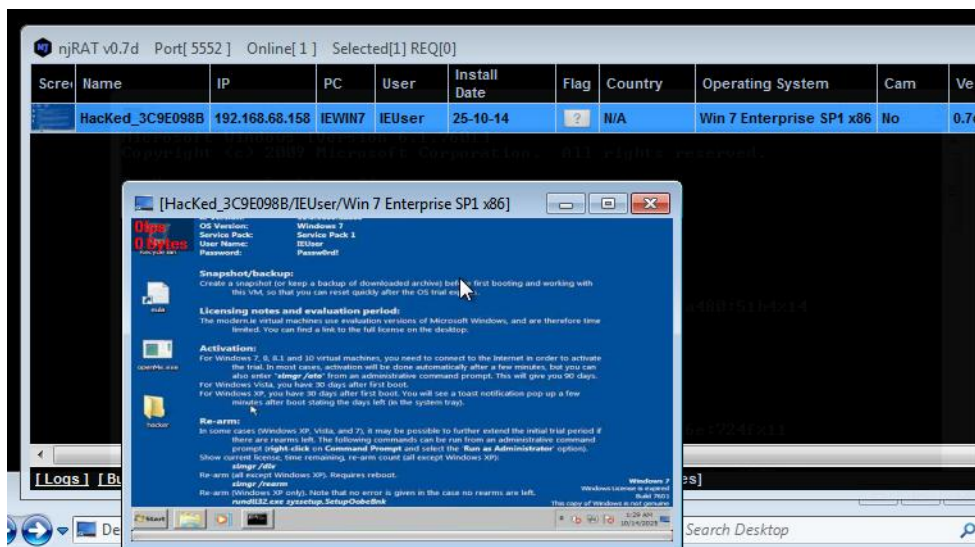


NTI Ethical Hacking Espionage and Data Collection

I first used njRAT to pull the system information from the victim. Instantly, we had their computer name, username, OS version, and more perfect intelligence gathering and got the files on the victim system and got the content of those files

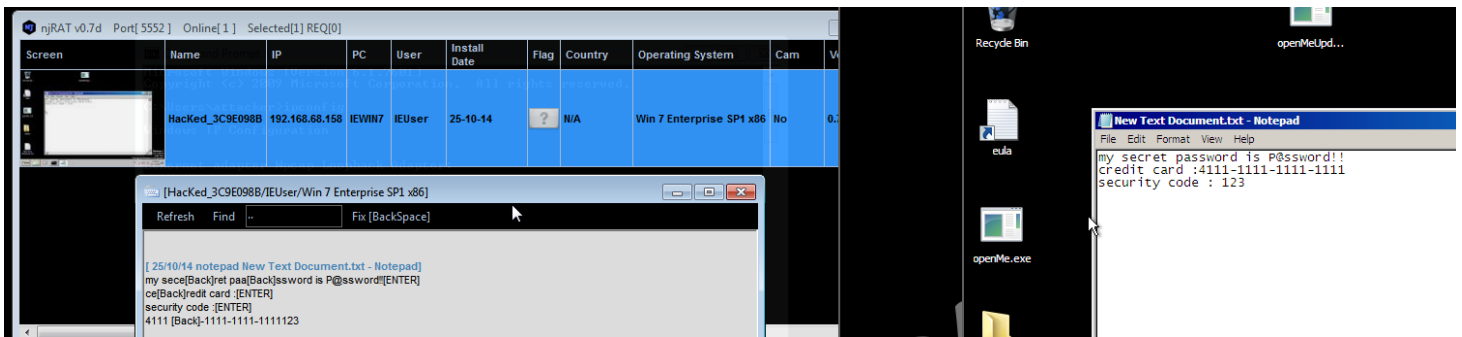


also I ran remote desktop access and I could do anything as running commands



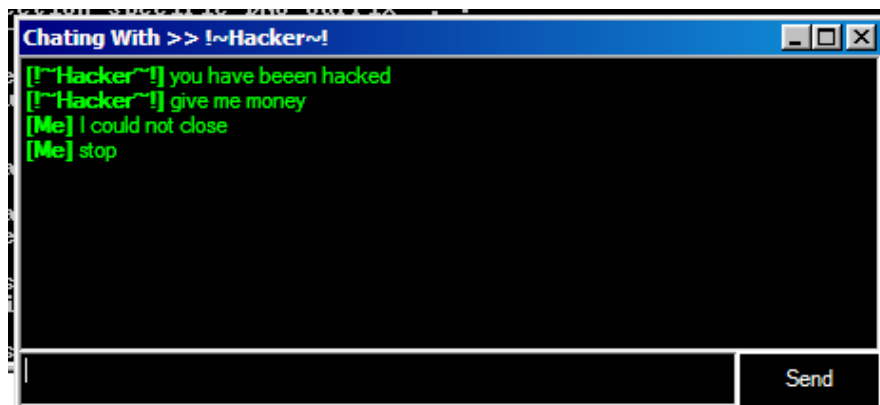
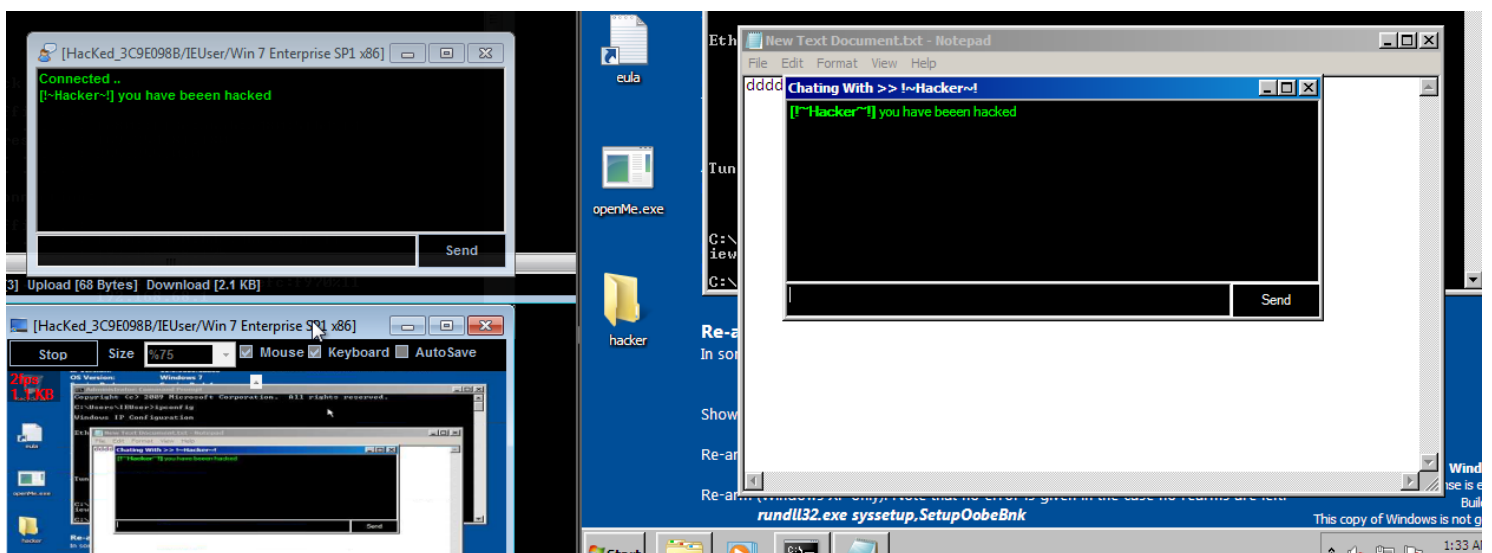
NTI Ethical Hacking

I activated the keylogger module. This silent tool began recording every single key pressed on the victim's keyboard. To simulate sensitive activity, we switched to the victim machine and typed fake credentials into Notepad



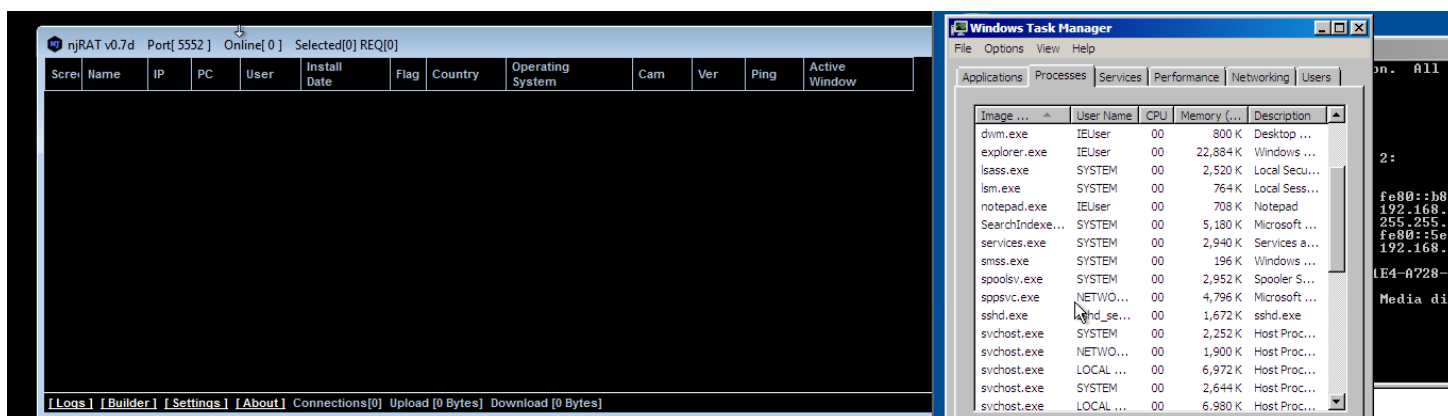
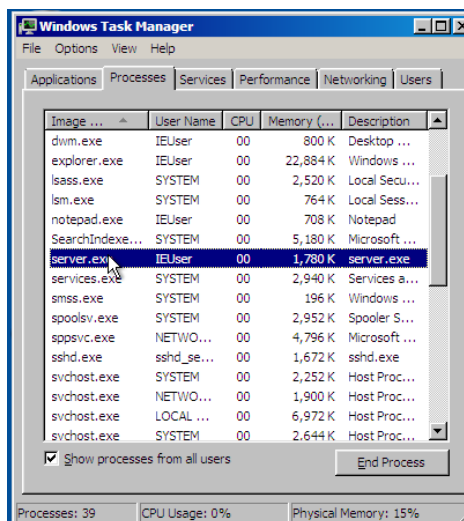
Then I returned to the handler, stopped the keylogger, and clicked "Get Logs." njRAT delivered a text file containing a perfect log of every keystroke we had just typed, including our fake passwords. The espionage was complete and successful.

Then I tried some features as opening a chat as I have done using ProRat and the victim can not close this chat even from task manager.

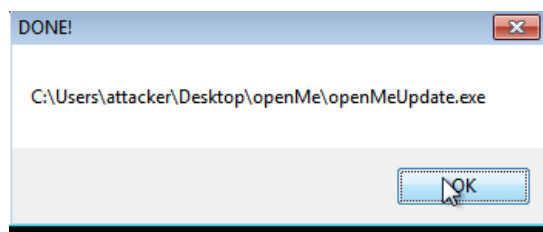
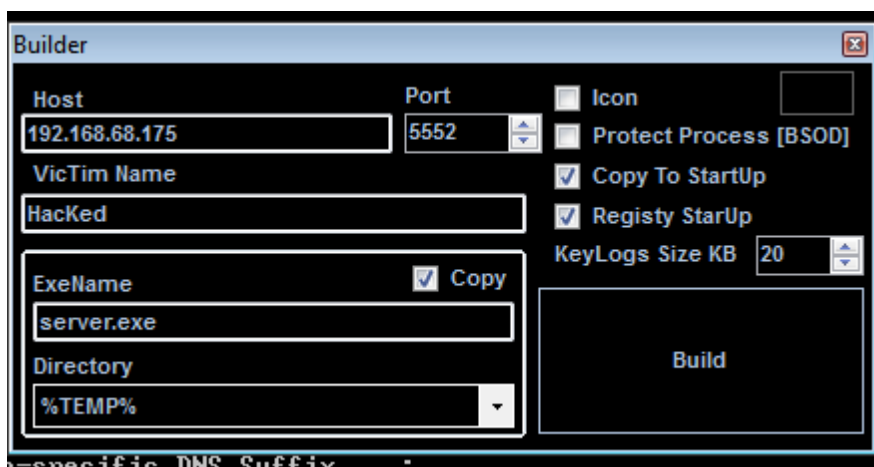


NTI Ethical Hacking

As a way of defense the victim can close this connection simply by going to task manager and end tasks of malicious files that looks unusual even he do not remember what he clicked or ran and simply the connection terminated.

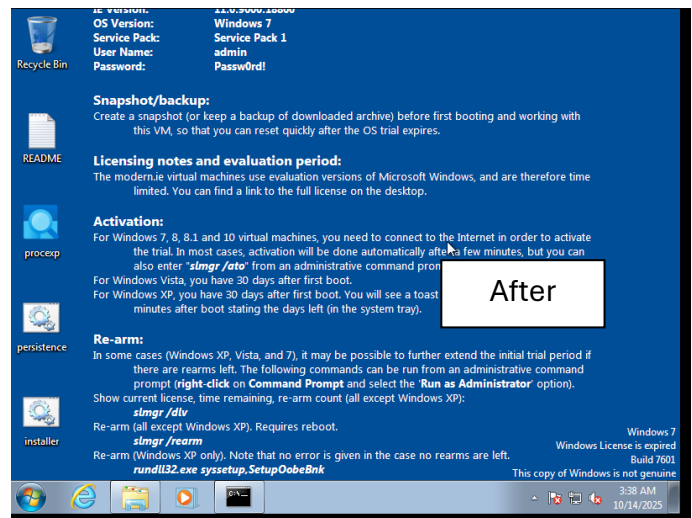
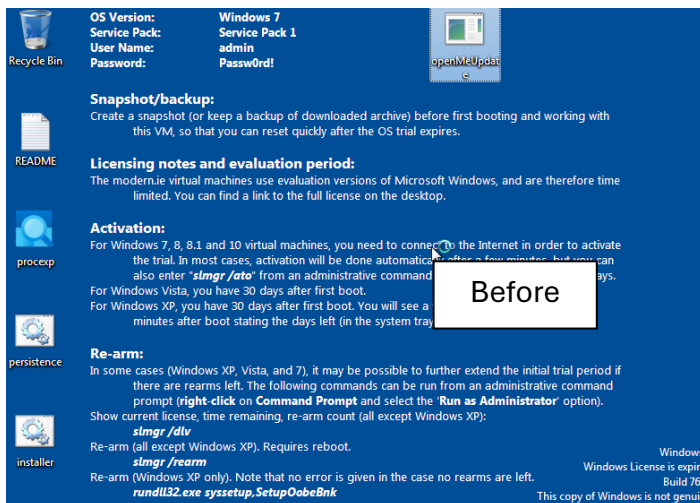


I did some updates to make my exe more persistent and stealthily.

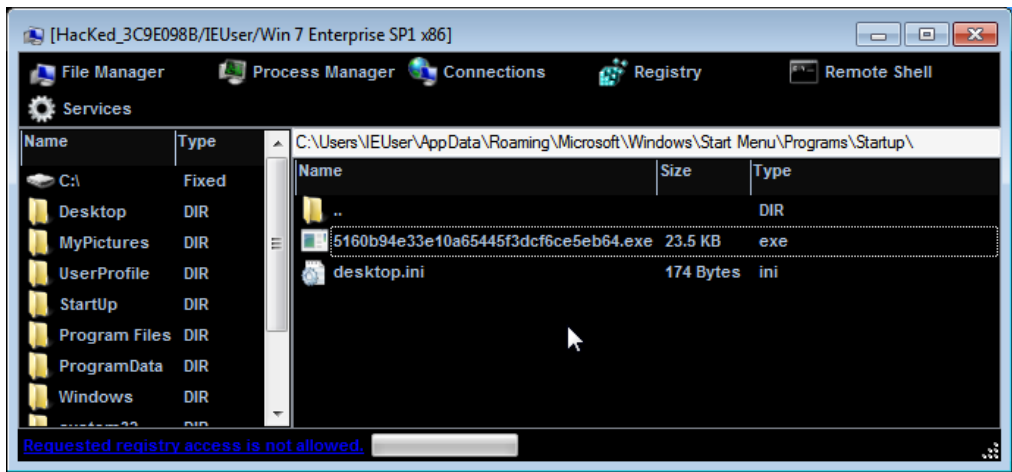


NTI Ethical Hacking

After running the file this time it disappeared after opening connection

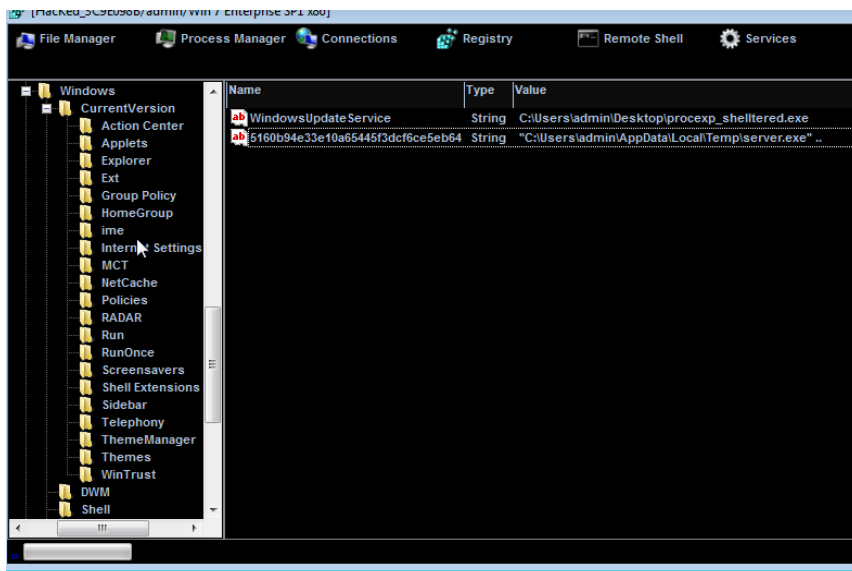


And also the file was put in the startup programs



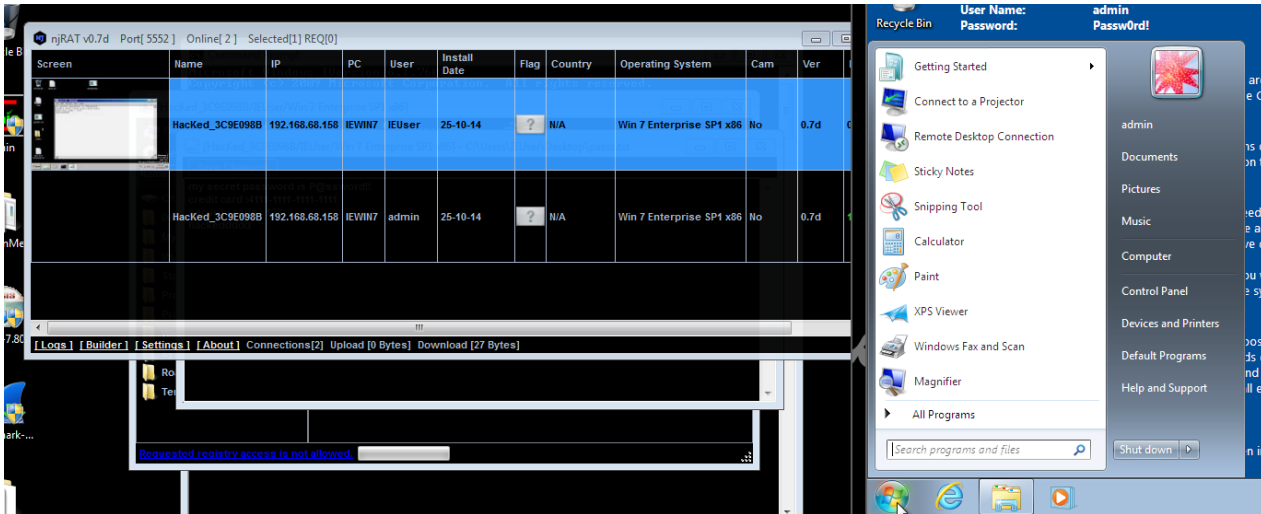
navigate to common AutoStart locations

like HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run.

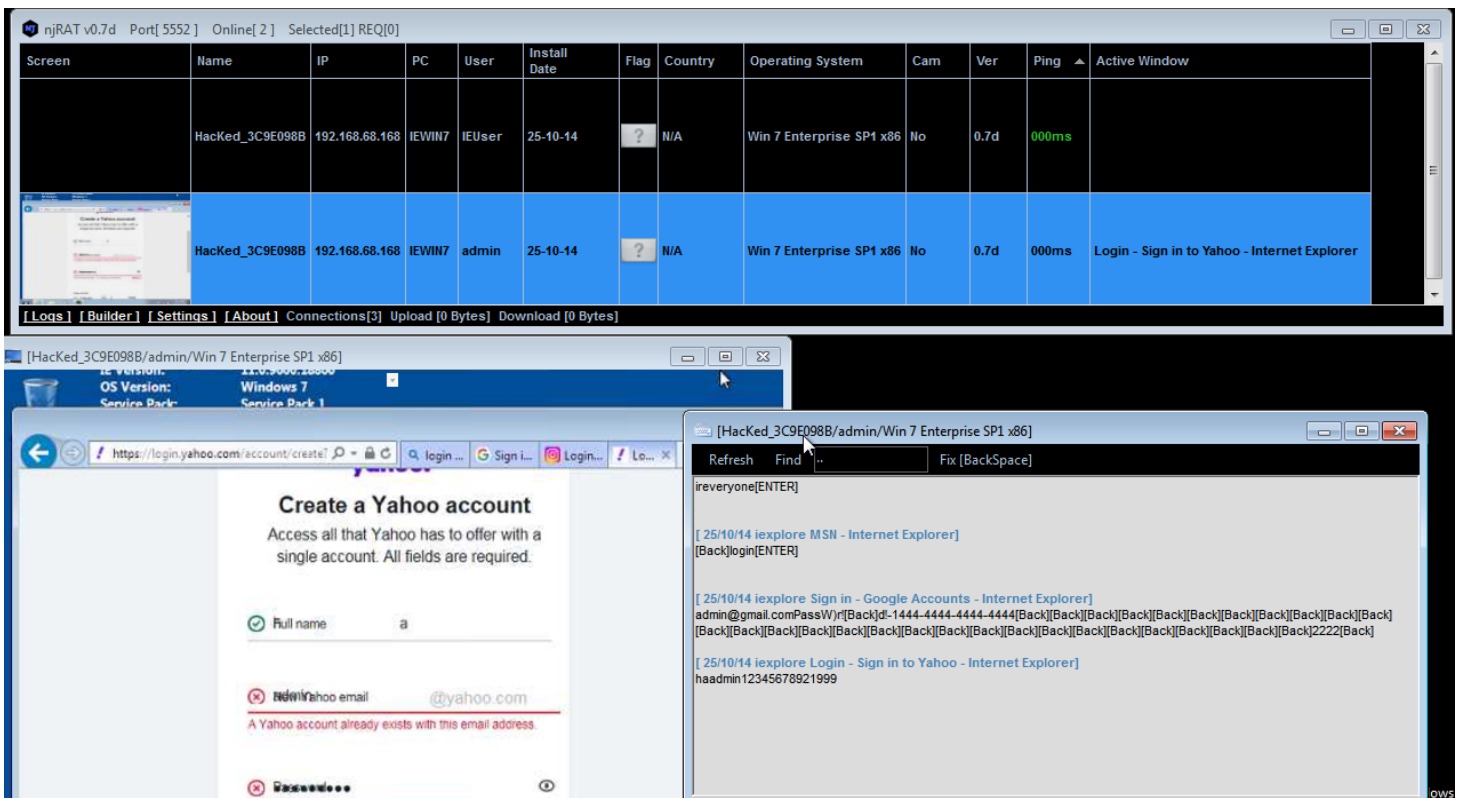


And then I created new admin user after logging in automatically the session started

And then I created new admin user after logging in automatically the session started



I activated the keylogger module. This silent tool began recording every single key pressed on the victim's keyboard. To simulate sensitive activity, we switched to the victim machine and typed fake credentials into Yahoo.

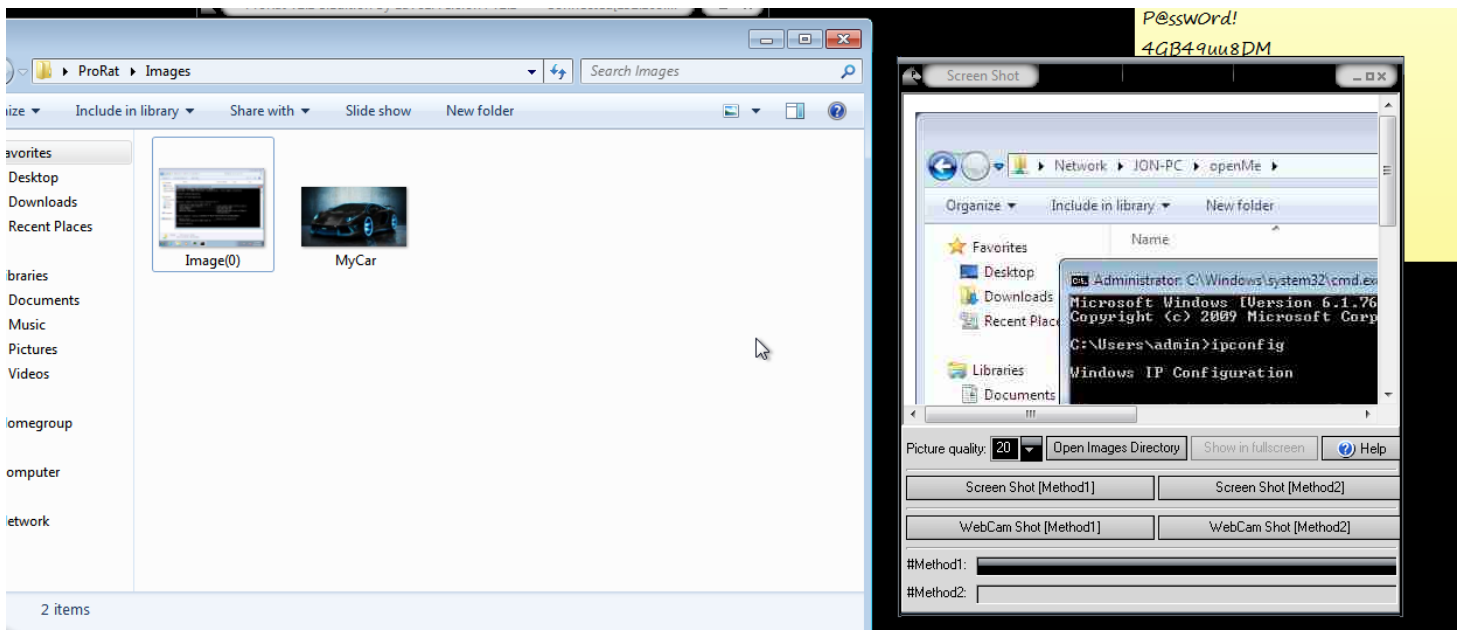


NTI Ethical Hacking

Then I returned to ProRat

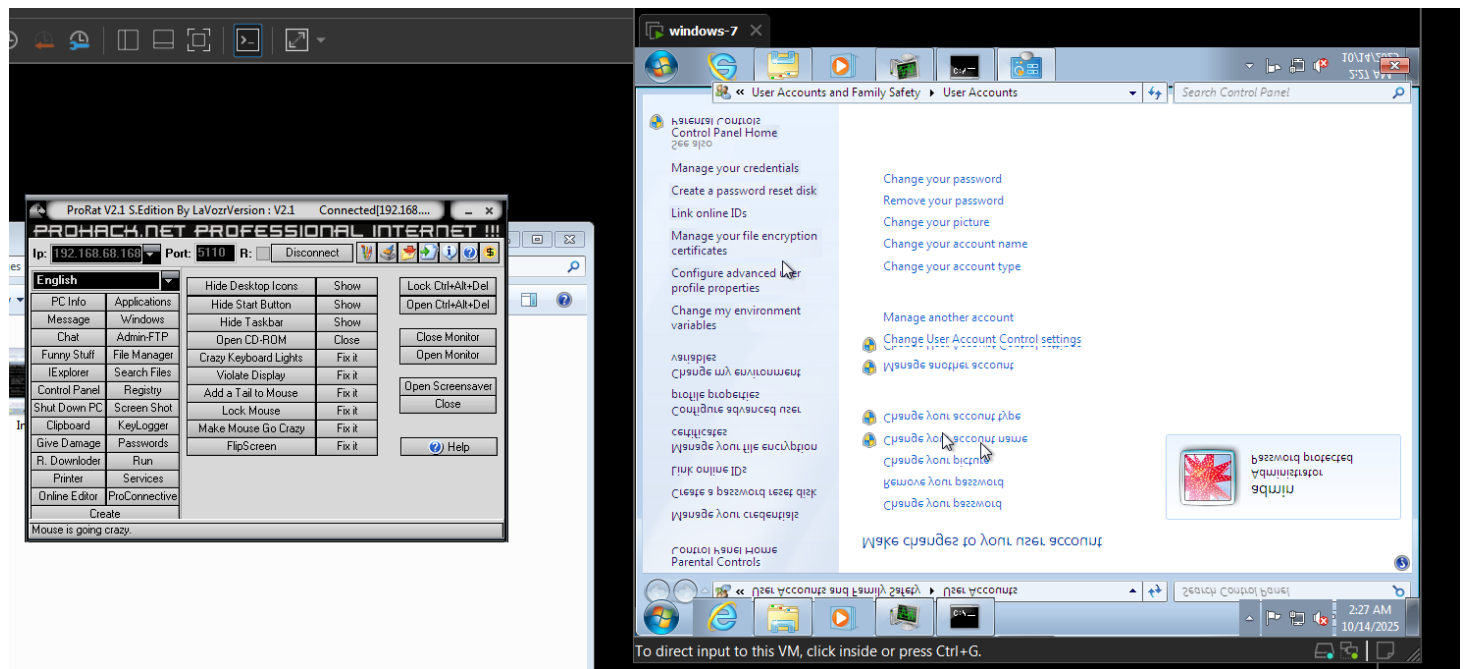
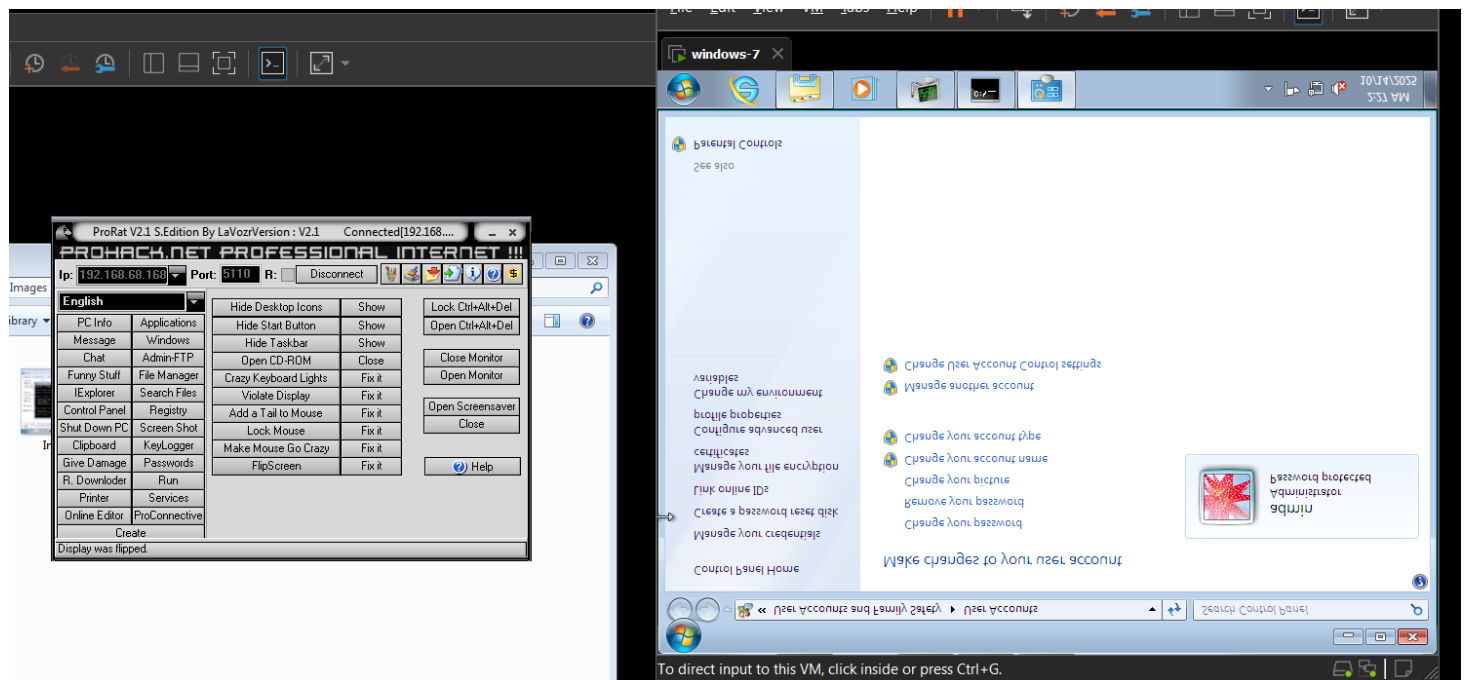


I activated the screenshot function. ProRat captured a live image of the victim's desktop and sent it back to us, proving we could see exactly what they were seeing in real-time.



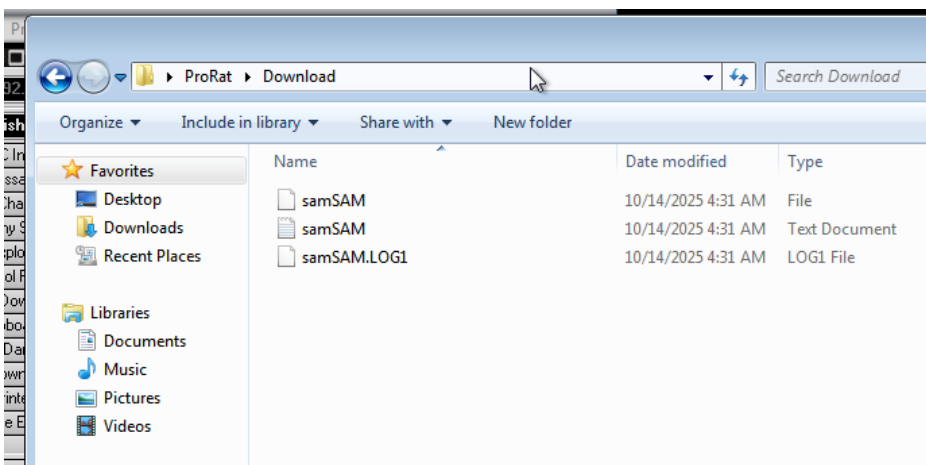
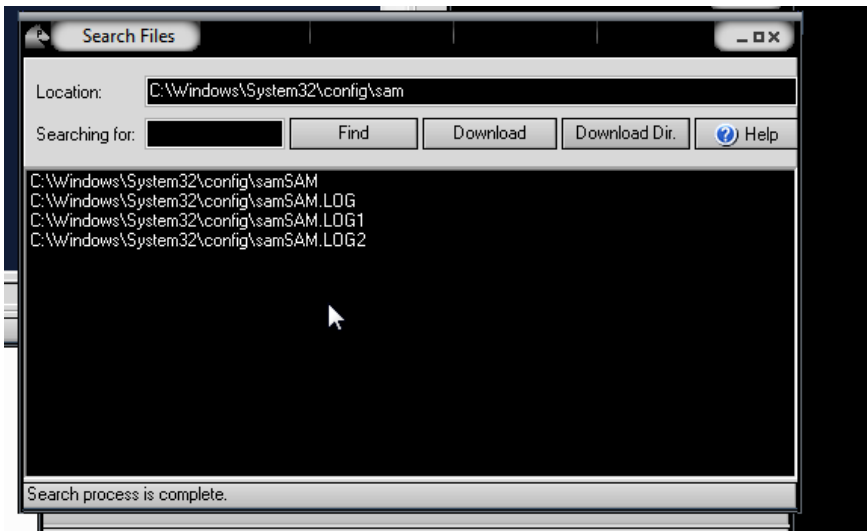
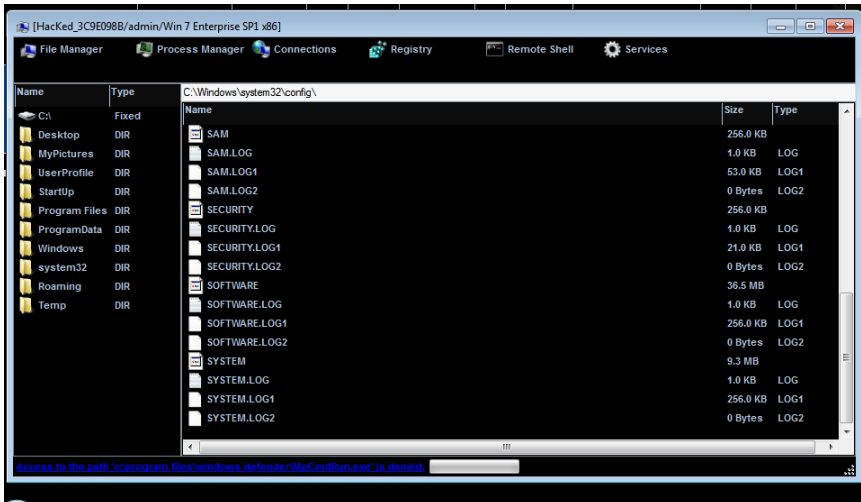
NTI Ethical Hacking

Also using ProRat I used funny stuff to flip the screen and make mouse go crazy



NTI Ethical Hacking

I could fetch some files as sam file using njRat and download it on my attacking machine using ProRat

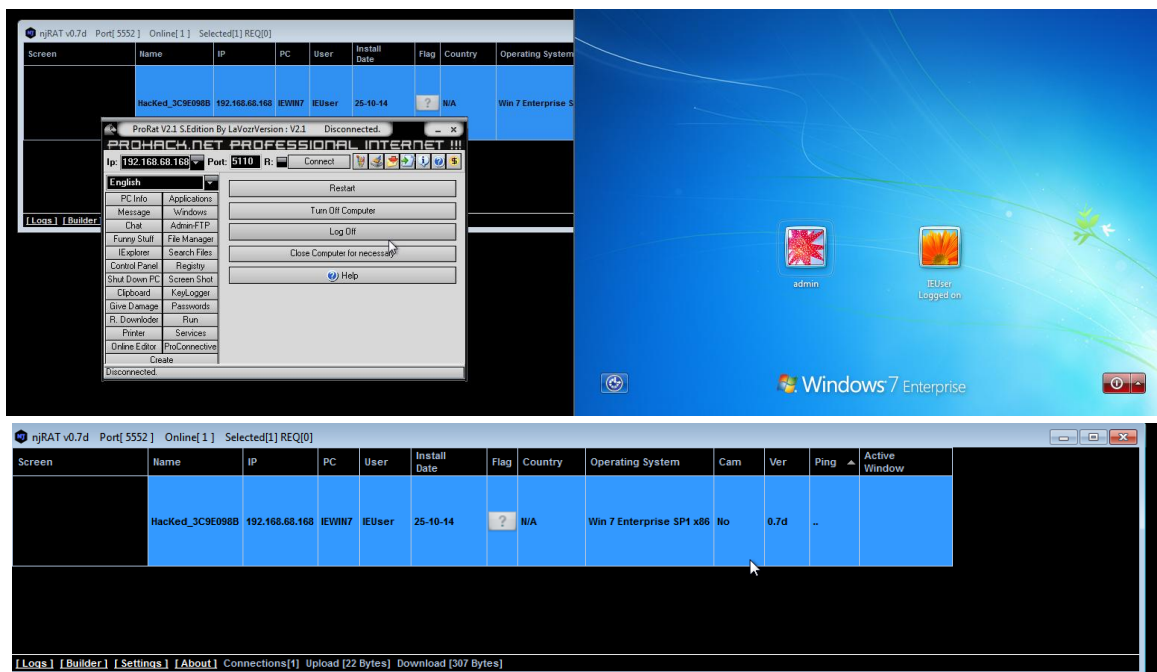


Then I could get the processes running and killed some processes

Then I could get the processes running and killed some processes

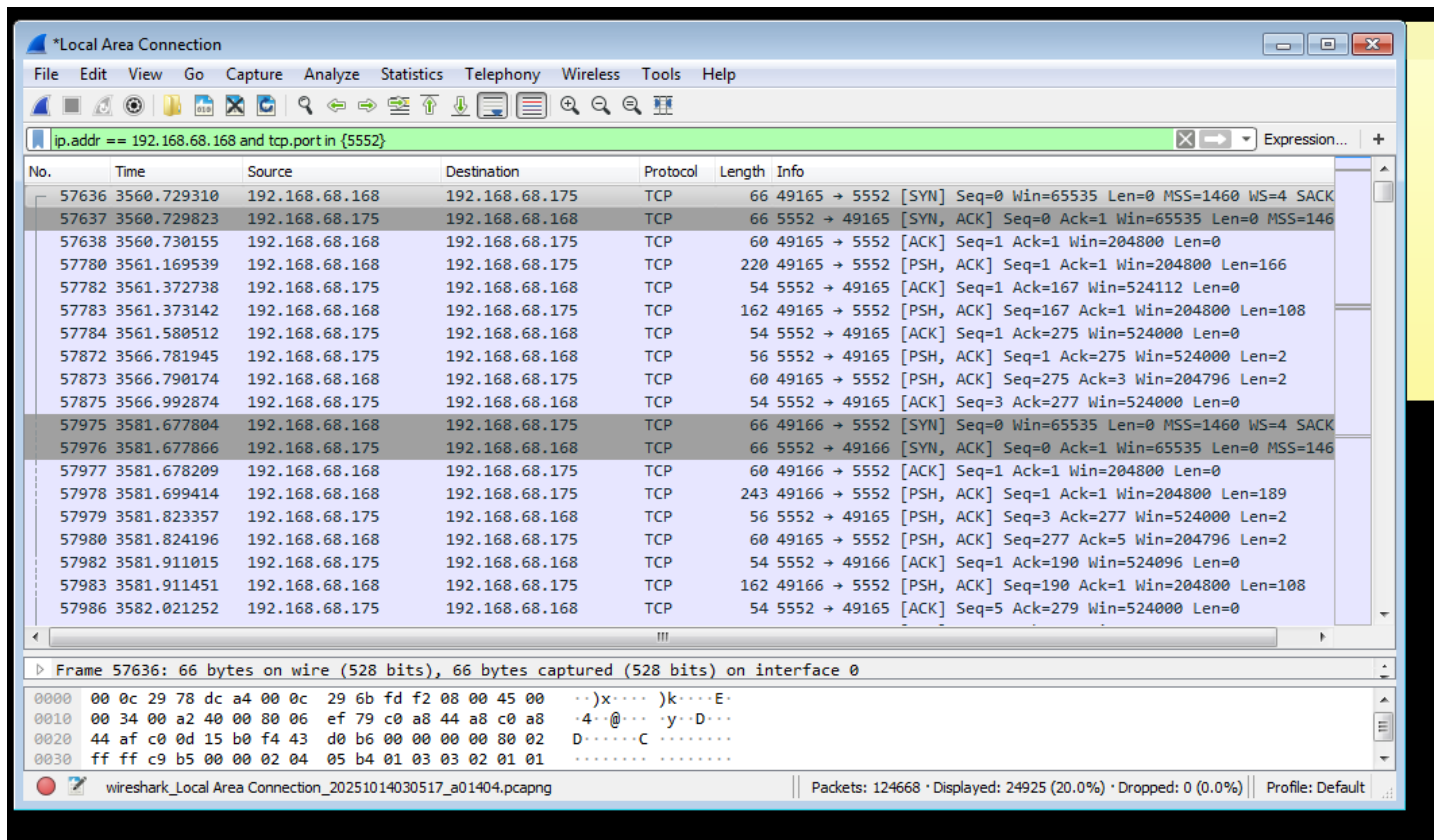


Using ProRat I could logoff the account



NTI Ethical Hacking

Also as extra I ran Wireshark to capture the whole traffic from the start of the attack and I got really great information that could help in detection and could be analyzed to help in detection and future prevention.



Security recommendations

Victims can get RAT in many social engineering techniques so let's see the prevention not only in our case

First backup to recover easy and always make your system patched and updates you also should learn about TTPs to know how attackers think to perform their attacks so you defend in greater way also call support if you have any issues and call the support directly from their trusted contacts and download software from trusted sources even it will cost you some money anything free you and your data must be the price also you should install antiviruses and EDR and enable multi-factor authentication as another layer of safety finally any resources not needed "unnecessary" as camera and microphone turn access off.

Guide helped me

<https://youtu.be/zTxuuYayUag?si=t3zTQqpRCtgVanFZ>
<https://youtu.be/h7VoAQwy14Y?si=V53PChLZDnct-x41>
https://youtu.be/lrlXBYCX1N4?si=QRn573K_eIRaf6Yf
<https://youtu.be/utd9EwwFXI?si=m1FPqN0lzmA92qUC>
<https://youtu.be/kyueZUfSWO4?si=5nUr76zNlORffU-h>
<https://www.kali.org/tools/shellter/#tool-documentation>